
Decoding Azure Active Directory Password Protection

Key Takeaways

- Azure AD (Microsoft Entra) Password Protection blocks weak and guessable passwords using Microsoft's global and custom banned lists, dynamic updates, and audit/enforcement modes, with consistent coverage across cloud and on-premises AD via the proxy and DC agent.
- Effective implementation combines strong length/complexity policies (and optional expiry) with MFA and Conditional Access, and a robust password evaluation flow to thwart password spray, credential stuffing, and brute-force attacks.
- Advanced posture comes from continuous monitoring, deception, and just-in-time privileged access; integrating Fidelis Active Directory Intercept adds real-time detection, adaptive defenses, and forensic response for a layered, compliant identity security program.

In 2024, the average cost of a data breach reached \$4.88 million, the highest on record. Alarmingly, 81% of these breaches were attributed to weak, reused, or stolen passwords. Users often create passwords that are simple and easily guessable, significantly increasing security risks. Furthermore, the average person managed approximately 255 passwords, underscoring the challenges of maintaining secure credentials.

These statistics highlight a critical vulnerability: inadequate password protection remains a primary gateway for cybercriminals. As organizations increasingly rely on [Microsoft Azure Active Directory](#) (Azure AD) for identity and access management, ensuring robust password security within this platform is imperative.

This article delves into Azure AD's password protection mechanisms, associated policies, and strategies to fortify credentials against evolving threats. Additionally, it examines how integrating solutions like [Fidelis Active Directory](#) Intercept can enhance the security of AD environments by providing comprehensive visibility and multi-layered defense.

Azure AD Password Protection at a Glance

Secure Your Credentials with Intelligent Password Policies

Key Features:



**Global & Custom
Banned Password Lists**



**Hybrid Environment
Support**



**Multi-Factor
Authentication**



**Dynamic Policy
Updates**



81%

of breaches stem from
weak or stolen passwords

\$4.88 million

The average cost of a data
breach in 2024



255 passwords

Average number of passwords
managed per person

Understanding Azure AD Password Protection

Azure AD Password Protection is a comprehensive solution that helps fix the most common cybersecurity vulnerability: ***weak or easy-to-guess passwords***.

It allows organizations to create a list of specific words or phrases that are not allowed to be used as passwords, along with a global list of banned passwords. This feature helps improve security. By using intelligent password policies, Azure AD Password Protection reduces the chance of attacks that target passwords, whether in cloud systems or on-premises AD setups.

Key Features of Azure AD Password Protection

1. Global Banned Password List

- Microsoft maintains a dynamic, continuously updated list of commonly used and weak passwords.
- The list is informed by extensive [threat intelligence](#), including password patterns frequently used in brute-force and dictionary attacks.
- Examples of banned passwords include predictable sequences (e.g., "123456"), popular phrases, and variations of "password."

This global list ensures a baseline level of security for all organizations using Azure AD.

2. Custom Banned Password List

- Organizations can define their own list of disallowed passwords, tailored to their specific needs.
- Words or phrases related to the organization (e.g., company name, product names).
- Industry-specific terms that attackers might guess.

This feature allows companies to address unique vulnerabilities and ensure users avoid predictable password patterns.

3. Dynamic Policy Updates

- Azure AD Password Protection leverages Microsoft's global security intelligence to regularly update banned password lists.
- This proactive approach ensures that newly identified weak passwords and patterns are blocked without manual intervention.
- Updates are applied across all environments seamlessly, reducing administrative overhead.

4. Audit and Enforcement Modes

- Audit mode allows organizations to monitor the impact of password protection policies without enforcing them immediately.
- Logs and reports highlight how often users attempt to use banned passwords.
- Helps administrators refine policies before full implementation.
- Enforcement mode actively blocks users from setting passwords that violate the policies.
- Ensures that all new and reset passwords comply with established security requirements.

5. Hybrid Environment Support

- Azure AD Password Protection extends its capabilities to on-premises AD environments through the Azure AD Password Protection DC Agent.
- This allows organizations to enforce cloud password protection policies across their entire infrastructure.
- Synchronization ensures consistency in password policies, regardless of whether users authenticate through on-premises or cloud directories.

6. Ease of Deployment

- The solution requires minimal configuration for Azure AD tenants.
- On-premises environments benefit from straightforward installation of the DC Agent and Password Protection Proxy.
- Once deployed, policies are applied automatically, reducing the administrative burden on IT teams.
- A password protection proxy server is necessary as part of the setup. It interacts with [Active Directory](#) to maintain banned password lists and enhance overall password security within an organization.

Watch Our Expert-Led Webinar
Safeguarding Active Directory in the Era of Cyber Threats

- Top Active Directory threats
- Learn how attackers gain access and how to prevent it
- Proactive strategies to strengthen your defenses

[Watch On-Demand Now](#)

Crack the Code:

Safeguarding Active Directory in the Era of Cyber Threats

Watch Now



Rami Mizrahi

VP, Engineering,
Fidelis Security



Paul Girardi

Cybersecurity Advisor
Fidelis Security



Mike Hoffman

Cofounder and CEO,
SNOKE CONNECT



Robert Fuchs

VP International Services,
Fidelis Security



Nick Copeland

Senior System Engineer,
Fidelis Security

Benefits of Azure AD Password Protection

1. Enhanced Security Posture

- Organizations' vulnerability to [brute-force](#) and credential-stuffing attacks is considerably reduced when they avoid using weak and easily guessable passwords.
- Dynamic updates ensure continued resilience against emerging threats.

•

[**Read whitepaper: Building Cyber Resilience: Detect, Manage and Recover from Attacks Quickly**](#)

2. Operational Efficiency

- Centralized management of password policies simplifies administration.
- Integration with both cloud and on-premises environments ensure consistent enforcement without requiring separate solutions.

3. Improved User Experience

- Educates users on creating stronger passwords by blocking insecure choices at the time of creation.
- Reduces the likelihood of account lockouts and breaches caused by compromised credentials.

4. Regulatory Compliance

- Supports adherence to security standards and legislation requiring strong password guidelines, such as NIST 800-63B and [GDPR](#).

How Azure AD Password Protection Prevents Attacks

[Azure AD](#) Password Protection is specifically designed to counter threats such as:

- **Password Spraying:**

Prevents attackers from exploiting common passwords across multiple accounts by blocking weak password usage at scale. Password spray attacks submit only a limited number of known weak passwords against many accounts, helping attackers avoid detection. Azure AD Password Protection blocks these attempts.

- **Credential Stuffing:**

Reduces the success of attackers using stolen credentials from [data breaches](#) by enforcing strong password policies.

- **Brute-Force Attacks:**

Limits the effectiveness of automated tools attempting to guess passwords through repeated trials.

By addressing these vulnerabilities, Azure AD Password Protection improves an organization's first line of defense against unwanted access.

Incorporating Azure AD Password Protection is an important step toward building a [secure identity](#) and access management structure that protects users and systems from credential-based attacks in a continuously changing digital ecosystem.

Microsoft Entra Password Protection

Microsoft Entra Password Protection is a powerful security feature that prevents users from creating weak or compromised passwords. This feature is critical for fighting against password spray attacks and other password-related threats. At its core, Microsoft Entra Password Protection uses a global and custom banned password lists to prevent widely used and easily guessable passwords.

Microsoft maintains the global banned password list, which is continually updated based on the most recent threat intelligence. This list covers passwords commonly used in attacks, such as "password123" and "qwerty." In addition, companies can create a custom banned password list based on their own requirements. This custom list can include words or phrases related to the

organization, such as the company name, product names, or industry-specific terms, ensuring that users avoid predictable password patterns.

By implementing these lists, Microsoft Entra Password Protection significantly reduces the risk of compromised passwords, enhancing the overall security posture of the organization.

Implementing Azure AD Password Policies

Strong password policies are essential to safeguarding user accounts and preventing unauthorized access. Azure AD offers robust features to enforce password hygiene and enhance identity protection.

The password protection proxy service plays a crucial role in managing and securing password policies within Azure Active Directory. This stateless relay allows on-premises domain controllers (DCs) to access Azure's banned password lists without requiring direct internet access, enhancing security and compliance for enterprises.

1. Password Complexity, Length, and Custom Banned Password List

Azure AD enforces stringent requirements to ensure passwords are difficult to guess or crack:

- **Minimum Length of 15 Characters:** A longer password increases the computational effort required for brute-force attacks, making them impractical.
- **Character Diversity:** Requires a mix of uppercase and lowercase letters, numbers, and special characters. This diversity significantly reduces the risk of successful attacks using dictionary-based methods.
- **Prohibition of Sequential or Repetitive Characters:** Prevents the use of patterns like "12345" or "aaaa," which are easily guessed.

Organizations can customize these settings to align with their security policies and enforce adherence at the time of password creation or reset. The evaluation process for a user's password when changing or resetting it includes checks for strength and complexity against banned password lists. Even if a user's password contains a banned term, it can still be accepted if it meets other strength criteria.

2. Password Expiry

While there is growing recognition that frequent password changes may do more harm than good by encouraging weak passwords, Azure AD supports environments that require periodic updates:

- **Customizable Expiry Periods:** Administrators can set policies to mandate password changes every 60, 90, or 180 days, depending on compliance needs.
- **Accountability and Alerts:** Azure AD alerts users when their passwords are nearing expiration, ensuring proactive updates and avoiding lockouts.

This functionality is especially beneficial in highly regulated businesses with strict password management norms.

3. Multi-Factor Authentication (MFA)

Passwords are insufficient to prevent unauthorized access, particularly if credentials are stolen

or shared. Azure AD adds [multi-factor authentication to improve security](#):

- **Layered Defense:** Combines password with something they own (mobile app, security token) or are (biometric data).
- **Conditional Access Policies:** Azure AD enables enterprises to impose MFA in high-risk scenarios, such as:
 1. Access from untrusted locations.
 2. Sign-ins from unmanaged devices.
 3. Suspicious or abnormal login behaviors.
- **Seamless User Experience:** With Azure AD, users can opt for passwordless authentication using FIDO2 security keys, Microsoft Authenticator, or Windows Hello, reducing reliance on traditional passwords.

Security Checklist: Harden Your Active Directory Today!

Download the checklist to learn best practices and strategies for:

- AD configuration
- Reduce attack surfaces
- Manage privileged accounts

[Get the Checklist Now](#)

Security Checklist

Beyond the Checklist

While the provided security layered approach that goes into these strategies:

- **Segmentation and Area Networks** or compartmentalization. Consider the Purdue with multiple network resources. This is after compromise.
- **Just-In-Time (JIT)** the minimum level accounts, as compared to Just-In-Time (JIT) Management (JITM). With JIT, elevate significantly minimize damage if a privilege is abused.
- **Deception Technology** – strong attackers away. By monitoring and which will allow.
- **Continuous Security** evolving threat implementing can centralized centralized view potential threat. However, relying hunting come actively search potential threat.
- **Privileged Access** They hold the solution is designed to

- ✓ Enable
- ✓ Re
- ✓ M

By implementing multi-layered defense, vigilance and ad

WHITE PAPER

Security Checklist: Hardening Your Active Directory with Advanced Strategies

Password Evaluation Process

When a user attempts to change or reset their password, the password evaluation process begins to confirm that the new password fits security requirements. The initial step in this process is to compare the password to the global banned password list and the custom banned password list. If the password matches any of the entries on these lists, it is instantly prohibited, and the user is required to provide a new password.

Beyond checking against banned password lists, the password evaluation process also assesses

the complexity and strength of the password. This includes ensuring the password meets minimum length requirements, contains a mix of uppercase and lowercase letters, numbers, and special characters, and does not include sequential or repetitive characters. If the password fails to meet these criteria, it is blocked, and the user must create a stronger password. This comprehensive evaluation process helps prevent the use of weak passwords and enhances overall security.

Deploying Azure AD Password Protection for On-Premises AD

Hybrid settings frequently rely on both on-premises and Azure AD. Azure AD Password Protection brings [cloud-based security](#) capabilities to traditional infrastructure, guaranteeing consistent password hygiene throughout the enterprise. By integrating with Windows Server Active Directory, Azure AD Password Protection helps combat security threats, particularly against common password attacks, by enforcing banned passwords and enhancing overall password security.

1. Installing the DC Agent

- The Domain Controller (DC) Agent is installed on every domain controller in the environment.
- It intercepts password change requests and validates them against Azure AD Password Protection policies.

2. Configuring the Password Protection Proxy

- The Password Protection Proxy acts as a communication bridge between on-premises domain controllers and Azure AD.
- It ensures policy synchronization, allowing administrators to maintain a unified password strategy across environments.

Step-by-Step: Deploying Azure AD Password Protection



Step 1: Install the DC Agent

The DC Agent intercepts password changes and validates them against Azure AD's password policies.



Step 2: Configure the Password Protection Proxy

The proxy acts as a bridge between on-premises domain controllers and Azure AD, synchronizing banned password lists and ensuring seamless policy enforcement.



Step 3: Enable Audit and Enforcement Modes

Enforcement Mode: Actively blocks weak passwords and enforces policies.

Enforcement Mode: Enforcement Mode: Actively blocks weak passwords and enforces policies.

3. Audit and Enforcement Modes

- **Audit Mode:** Logs non-compliant password attempts without enforcement, allowing organizations to monitor user behavior and adjust policies as needed.
- **Enforcement Mode:** Actively blocks non-compliant passwords during creation or reset, ensuring full policy adherence.

This hybrid approach enables seamless password protection and bridges the gap between cloud and on-premises security.

Advanced Strategies for Azure AD Security

Securing Azure AD requires more than just password protection. Advanced strategies provide proactive defenses to counter sophisticated threats.

1. Continuous Monitoring and Threat Detection

- **Azure Sentinel:** A cloud-native SIEM tool that analyzes sign-in behaviors, detects anomalies, and correlates security events.
- **Fidelis Active Directory Intercept:**
 1. Monitors AD activities in real time, providing insights into user logins, privilege escalations, and unusual behavior.
 2. Detects specific attacks, such as password spraying or brute force, and alerts administrators before they escalate.
 3. Identifies configuration gaps that attackers could exploit.

2. Deception Technology

Fidelis Active Directory Intercept employs [intelligent deception](#) to mislead attackers:

- **Decoy AD Objects:** Creates fake user accounts, groups, and other assets that mimic real resources.
- **Strategically Placed Breadcrumbs:** Diverts attackers toward decoys, buying defenders time to analyze and respond.
- **Actionable Alerts:** Provides high-confidence alerts when decoys are engaged, pinpointing active threats.

3. Just-In-Time Access

Azure Privileged Identity Management (PIM) ensures administrative accounts are only elevated when necessary:

- **Time-Bound Privileges:** Users are granted elevated permissions for specific tasks and durations.
- **Reduced Attack Surface:** Limits the exposure of administrative credentials to potential attackers.
- **Detailed Logging:** Tracks all activities performed during elevated access, enabling [audits](#) and accountability.

Licensing and Requirements

To utilize Microsoft Entra Password Protection, organizations must have a valid Microsoft Entra license. This feature is included in the Microsoft Entra P1 and P2 plans and can also be

purchased as a standalone license. In addition to the licensing requirement, organizations must have a valid Azure AD tenant, and users must be synchronized with Azure AD.

Microsoft Entra Password Protection can be deployed in both on-premises and cloud environments, providing flexibility for different organizational needs. The feature can be managed using the Azure AD portal or PowerShell, allowing administrators to configure and enforce password policies effectively. By meeting these licensing and deployment requirements, organizations can leverage Microsoft Entra Password Protection to enhance their security posture and protect against password-based threats.

Enhancing Password Protection with Fidelis AD Intercept

While Azure AD provides strong native protections, integrating [Fidelis Active Directory](#) Intercept elevates security to a new level.

Feature Azure AD + Fidelis Password Policies Strong Adaptive with intelligence Threat Detection Moderate Real-time, with decoys Forensic Analysis Limited Detailed logs and insights

1. Enhanced Visibility

- Provides a detailed overview of AD entities, including user accounts, group memberships, and configurations.
- Monitors both normal and anomalous behaviors, giving administrators a comprehensive understanding of their security posture.

2. Integrated Response Tools

- **Automates responses to detected threats:**
 - Blocking unauthorized attempts.
 - Resetting compromised credentials.
- **Facilitates forensic analysis** by providing logs and insights into attack vectors.

3. Adaptive Security

- Aligns with [MITRE ATT&CK frameworks](#) to identify and mitigate evolving threats.
- Continuously improves defenses by learning from observed attacks and updating detection methods.

Conclusion: Securing Passwords, Strengthening Defense

With 81% of data breaches linked to compromised credentials, robust password security is critical. Azure AD Password Protection offers a strong defense through intelligent policies, banned password lists, and hybrid environment support, ensuring a resilient security foundation. Features like Multi-Factor Authentication and Conditional Access further mitigate risks.

For advanced protection, integrating Fidelis Active Directory Intercept provides enhanced visibility, swift threat response, and [proactive defenses](#) like intelligent deception and real-time monitoring. Together, these tools create a layered security strategy that not only protects your organization but also strengthens trust and compliance.

Investing in these solutions now is key to staying ahead of evolving threats and safeguarding your digital ecosystem effectively.

Things you'll learn about:

- Real-Time Threat Detection and Proactive Defense
- Intelligent deception techniques
- Forensic analysis

[Download the Datasheet](#)

[Book a Demo Now!](#)

Datasheet

Fidelis



Multi-layered Defense

Active Directory (AD) is the enterprise's management. It authenticates and authorizes, provides for the storage and deployment of services such as management, and more. launch point from which to escalate privileges, and execution, data exfiltration.

Protecting AD is a prime target. But many tools fall short in imminent attack. And or game over. They can't network traffic and data protection tools.

That's where Fidelis Active Directory Intercept comes in.

See More. Stop Only with Active Directory Intercept.

Fidelis Active Directory Intercept technology with four just identify AD threat. Intercept gives you exactly how, where, into your network, and ability to defend against.

Fidelis Active Directory Intercept™
Multi-Layered Active Directory Defense

Frequently Asked Questions

How does Azure AD Password Protection handle hybrid environments?

Azure AD Password Protection integrates seamlessly with hybrid setups by using the DC Agent and Password Protection Proxy. This ensures consistent enforcement of password policies across both on-premises and cloud directories.

What is the difference between Audit Mode and Enforcement Mode in Azure AD Password Protection?

Audit Mode logs and reports non-compliant password attempts without blocking them, allowing organizations to monitor and refine policies. Enforcement Mode actively blocks users from setting passwords that violate the policy, ensuring full compliance.

Does Azure AD Password Protection work with passwordless authentication methods?

Yes, Azure AD supports passwordless authentication methods like FIDO2 security keys, Microsoft Authenticator, and Windows Hello. These methods reduce reliance on traditional passwords, further enhancing security.